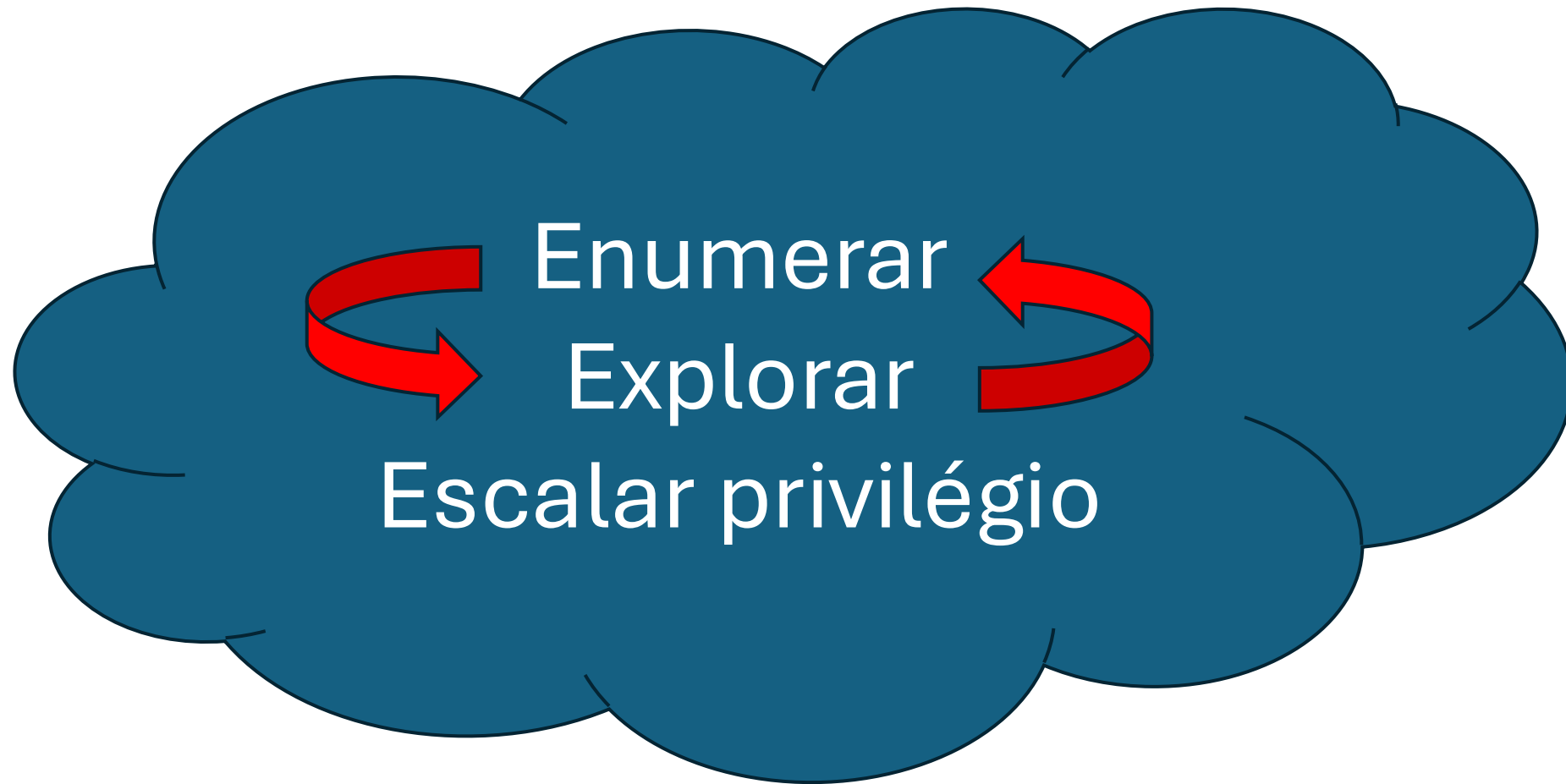


TAC - OFFSEC

Aula 03



Prof. Roberto Rodrigues-Filho
Dept. de Ciência da Computação (CIC)
Universidade de Brasília (UnB)





Explorando...

Durante a exploração, eu achei uns trem esquisito:

- 891c74de3c0432044e586ad8daf24db0
- dmFtbyBwcmEgY2ltYSBjYW1iYWRRhISE=
- 6f 70 61 21 20 65 20 61 67 6f 72 61 3f
- id_rsa

E agora?





roberto.filho@unb.br

HASHCAT

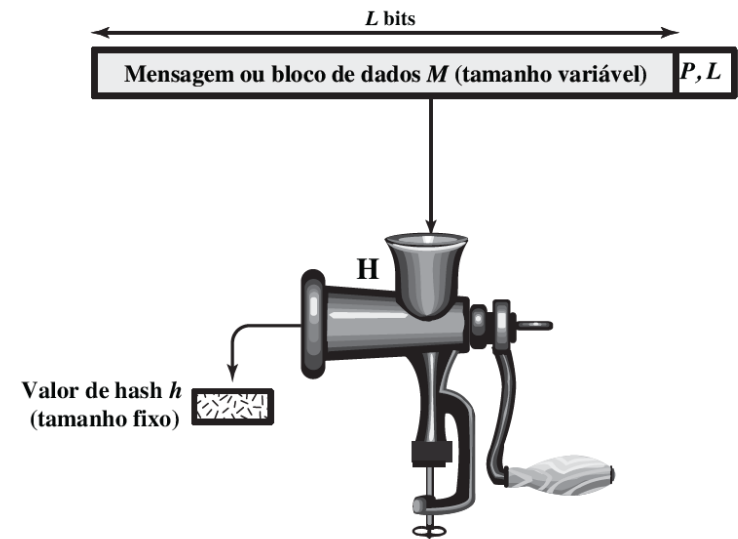


Hash? O que é Hash?

Antes de explicar o que é, vamos entender por que utilizá-lo!



- Garante a integridade da mensagem
- Uma ótima forma de armazenar ser

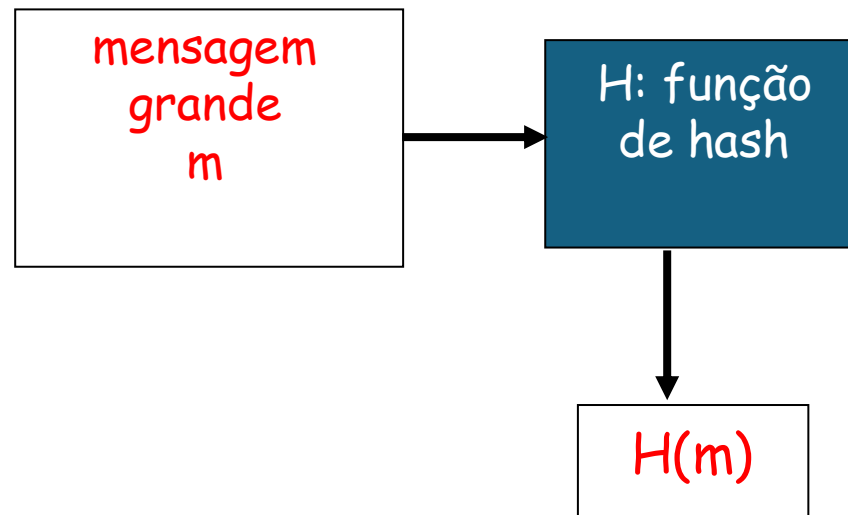


P, L = preenchimento mais campo de tamanho

Hash? O que é Hash?

O que é?

- Função matemática que recebe uma entrada de qualquer tamanho e gera uma saída de tamanho fixo.

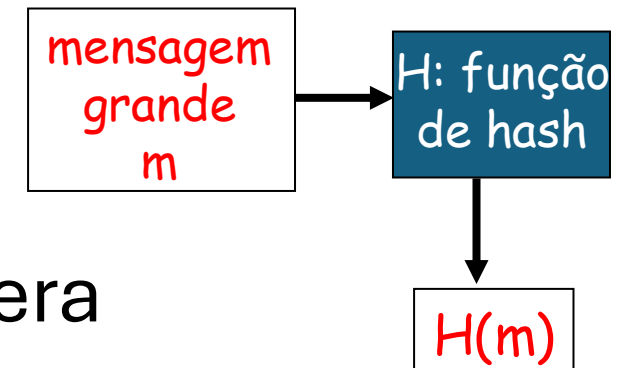


Hash? O que é Hash?

O que é?

- Função matemática que recebe uma entrada de qualquer tamanho e gera uma saída de tamanho fixo.

- Determinístico
- Rápido de calcular
- Difícil de inverter (com a saída você não recupera a entrada)
- Resistente a colisão



Hash? O que é Hash?

Requisito	Descrição
Tamanho de entrada variável	H pode ser aplicado em um bloco de dados de qualquer tamanho.
Tamanho da saída fixo	H produz uma saída de tamanho fixo.
Eficiência	$H(x)$ é relativamente fácil de calcular para qualquer valor de x informado, através de implementações tanto em hardware quanto em software.
Resistência à pré-imagem (propriedade de mão única)	Para qualquer valor de hash h informado, é computacionalmente impossível encontrar y , de modo que $H(y) = h$.
Resistência à segunda pré-imagem (resistência à colisão fraca)	Para qualquer bloco x informado, é computacionalmente impossível encontrar $y \neq x$ com $H(y) = H(x)$.
Resistência à colisão forte	É computacionalmente impossível encontrar qualquer par (x, y) , de modo que $H(x) = H(y)$.
Pseudoaleatoriedade	A saída de H atende os testes padrão de pseudoaleatoriedade.

Em CTF... Onde o HASH aparece?

- Dump de banco de dados
- Arquivos de configuração / código-fonte vazado
- Tráfego de rede (PCAP)
- Logs de sistemas
- Flags hasheadas...



Em CTF... Onde o HASH aparece?

```
password_hash = "5f4dcc3b5aa765d61d8327deb882cf99"
```

- Arquivos de configuração
- Tráfego de rede
- Logs de sistema
- Flags hashado



Em CTF... Onde o HASH aparece?

```
salt = "abc123"
```

- Du `hash = SHA256(salt + password)`

- Arquivos de configuração
- Tráfego de rede
- Logs de sistema
- Flags hashado



Em CTF... Onde o HASH aparece?

```
token = md5(username + secret_key)
```

- Dump de banco de dados
- Arquivos de configuração
- Tráfego de rede
- Logs de sistema
- Flags hashado



Em CTF... Onde o HASH aparece?

```
if sha1(input) == "abc123...":  
    print("Access granted")
```

- Arquivos de configuração / código fonte vazado
- Tráfego de rede
- Logs de sistema
- Flags hasheadas



Código
vazado
BACKEND!

Em CTF... Onde o HASH aparece?

- ```
if (md5(password) == stored_hash)
```
- Arquivos de configuração
- Tráfego de rede
- Logs de sistema
- Flags hashado



Hash no  
**FRONTEND!**  
Dios mio!

# O que fazer quando encontro um HASH?

1. Entender que aquilo pode ser uma credencial
2. Identificar o tipo de HASH
  - a) qual algoritmo?
  - b) tem salt?
- 3. Quebrar a hash!**
  - a) Força bruta
  - b) Dicionário





# Identificando a HASH!

<https://www.kali.org/tools/hash-identifier/>

<https://www.kali.org/tools/hashid/>

<https://www.kali.org/tools/hashcat/>

<https://www.tunnelsup.com/hash-analyzer/>

<https://gchq.github.io/CyberChef/>

<https://10015.io/tools/md5-encrypt-decrypt>

<https://crackstation.net/>

**ANOTE NO SEU  
CHEAT SHEET!**



# Identificando a HASH!

- Identificando a HASH

Use algum identificador de HASH

**hashid:** \$hashid -m xxx

**Hash Analyzer:** <https://www.tunnelsup.com/hash-analyzer/>

Tentem bater com o que vocês encontrarem na wiki do Hashcat

[https://hashcat.net/wiki/doku.php?id=example\\_hashes](https://hashcat.net/wiki/doku.php?id=example_hashes)



# Identificando a HASH!

- Identificando a HASH

**ATENÇÃO! ÀS VEZES NÃO É HASH**

## HEX:

Caracteres: 0–9 e a–f

Sem símbolos especiais (+, /, =)

Normalmente tamanho par

Exemplo: 48656c6c6f

## Base64:

Caracteres: A–Z a–z 0–9 + /

Pode terminar com = ou ==

Tamanho múltiplo de 4

Exemplo: SGVsbG8=

**CyberChef**

<https://gchq.github.io/CyberChef/>





# Identificando a HASH!

- Identificando a HASH
- 5f4dcc3b5aa765d61d8327deb882cf99
- dmFtbyBwcmEgY2ltYSBjYW1iYWRRhISE=
- 6f 70 61 21 20 65 20 61 67 6f 72 61 3f





# Quebrando HASH!

- Quebrando HASH

```
$ hashcat -help
```

```
$ hashcat -m <algo> -a <forma> hash.txt <dicionario/mascara/_>
```



# Quebrando HASH!

## Exemplos:

482c811da5d5b4bc6d497ffa98491e38

4149c5cc4c378444d116d65ad5ba4099 -> letras e números – 6 caracteres

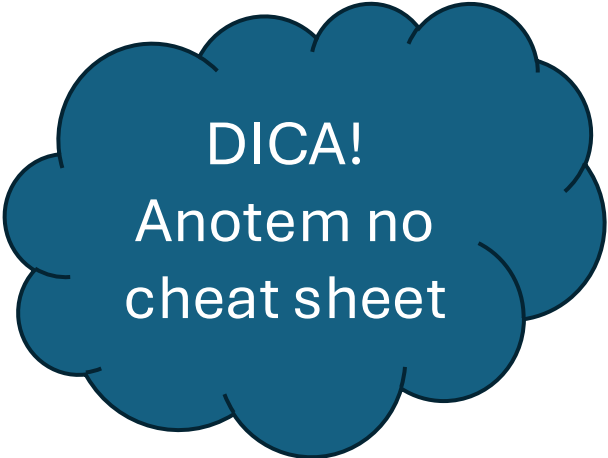


# SSH conexão chave privada

- Achou um id\_rsa??
- Então, podemos conectar por SSH usando a chave!

```
$ chmod 600 id_rsa
```

```
$ ssh -i id_rsa <usuario>@<ip> -p <porta>
```



DICA!  
Anotem no  
cheat sheet



## VAMOS VALIDAR NOSSO CONHECIMENTO?

Três salas:



TryHackMe -> <https://tryhackme.com/room/crackthehash>